

KEVIN ALEXANDER

Mobile: 904-917-9238 • Email: kevintrevalexander@gmail.com • Jacksonville FL 32258
<https://www.linkedin.com/in/kevin-t-alexander/>

GRC Specialist | Cybersecurity Auditor | Compliance Analyst | PCI DSS Consultant

Summary

Governance, Risk, and Compliance Specialist, adept at assisting organizations in achieving and sustaining compliance across numerous frameworks and industries. Strives to minimize scope effectively, leading to cost savings for the company and enhancing overall profitability. Results-oriented professional with a demonstrated history of effectively implementing and overseeing comprehensive security measures to protect sensitive data and ensure adherence to industry regulations. Committed to delivering tangible outcomes and preserving organizational assets through the application of cutting-edge security practices. Proficient in conducting meticulous risk assessments, formulating and executing strategies to enhance both physical and digital security, and establishing resilient control frameworks. Bringing experience in overseeing incident response protocols and collaborating with diverse stakeholders to uphold compliance. Skilled in constructing and leading high-achieving security teams, fostering a culture of continual improvement.

Areas Of Expertise

Security & Compliance Frameworks

- Payment Card Information Data Security Standard (PCI DSS) 3.2.1 & 4.0
- National Institute of Standards and Technology (NIST) 800-53
- NIST CSF 2.0 (Cybersecurity Framework)
- HIPAA (Health Insurance Portability and Accountability Act)
- SOC 2 (Service Organization Control 2)
- CIS Controls (Center for Internet Security Controls)
- MITRE ATT&CK Framework

Security Tools

- Archer GRC Tool
- ServiceNow
- Microsoft Power BI

Security Strategy

- Information Security Policy
- Governance
- Risk Management
- Compliance
- Cryptography

Professional Experience

Sr. Cybersecurity Specialist | Lexvorvin (Abbott | BaxterClewis) October 2023 to Present

- Conducted **risk** assessments for system and user exception requests to evaluate non-compliance with enterprise **policies**. Collected **risk** classification **data**, analyzed vulnerabilities, assessed website and USB access requests for **security** risks, and determined **risk** levels before routing approvals to business **leadership**. This improved stakeholder visibility, secured funding for remediation, and strengthened **data** loss prevention (DLP) **controls**.
- Instrumental in migrating User and System Exception Processes from Archer GRC to ServiceNow to streamline **risk management** workflows. Mapped Archer fields to ServiceNow, aligned workflows, and ensured seamless **data** transition. This enhanced efficiency, reduced manual processing time, and improved tracking of exception approvals for **compliance management**.
- Led **risk** assessments and **compliance** evaluations for third-party **vendor** contracts to align with **organizational risk** tolerance. Implemented methodologies to assess inherent and residual risks, identified control gaps, and negotiated **security** terms. This strengthened **vendor relationships**, minimized disruptions, and reduced third-party **security** risks.
- Streamlined PCI DSS audits by optimizing Archer GRC for Self-Assessment Questionnaires (SAQs) and Reports on **Compliance** (ROCs). Reviewed **best practices**, automated **compliance** checks, and refined workflows to improve accuracy and efficiency. This enhanced audit readiness, ensured timely **compliance**, and reduced overall **risk** exposure.
- Conducted PCI DSS audits, aligning **security controls** with **NIST** Cybersecurity Framework (CSF) 2.0 and General **Data** Protection Regulation (GDPR) requirements. Developed Information **Security Policies**, performed **risk** assessments, and mapped **security controls** to **compliance** needs. This improved cybersecurity posture, reduced risks, and strengthened resilience.
- Developed **compliance** documentation and scoped assessments by reviewing Reports on **Compliance** (ROCs), Attestations of **Compliance** (AOCs), and Master Service Agreements (MSAs). Created Information Request Lists (IRLs) to determine scope, avoiding unnecessary assessments. This streamlined **compliance** efforts, reduced costs, and improved audit efficiency.
- Designed **Data** Flow Diagrams (DFDs) and **Data** Flow Narratives (DFNs) to map cardholder **data** flow for PCI DSS **compliance**. Assessed system **architecture**, analyzed Information Request Lists (IRLs) and Document Request Lists (DRLs), and documented **data** collection, processing, and storage. This clarified **compliance** needs, reduced **risk** exposure, and improved **security**.
- Led a **team** of cybersecurity consultants, managed deliverables, and provided **compliance** training to support audits and **risk management**. Held weekly **management** meetings, conducted training sessions, and consolidated findings into executive reports. This ensured **compliance** alignment, improved **team** efficiency, and strengthened stakeholder **communication**.

Cybersecurity Specialist | EMK Properties

April 2016 - September 2023

- Managed and expanded the Third-Party **Risk Management** (TPRM) program, collaborating with the **IT** and legal teams to implement **controls** aligned with internal standards and frameworks. Evaluated and mitigated inherent risks associated with

third-party vendors through thorough assessments (utilizing the NIST CSF) and ongoing monitoring. Enhanced organizational resilience by ensuring compliance with security standards and mitigating potential risks, safeguarding sensitive data and maintaining the company's reputation and operational continuity.

- Employed tools like Archer GRC, ServiceNow, and Power BI to enhance audit readiness and regulatory compliance by integrating compliance controls and automating audit scheduling, tracking, and reporting. Leveraged Archer for control management, ServiceNow for incident tracking and workflow automation, and Power BI for real-time audit insights and reporting. This approach significantly reduced manual effort, improved audit accuracy, and strengthened the organization's regulatory adherence and resilience.
- Spearheaded the creation of company documentation such as Incident Response Plans, Service Level Agreements (SLAs), Standard Operating Procedures (SOPs), Security Awareness Training Materials, and Information Security Policy from inception to completion by employing technical writing expertise. This ensured policies were practical and aligned with organizational objectives and regulatory frameworks (GDPR, FTC, CCPA, PCI DSS etc), fostering a culture of security awareness and adherence.
- Analyzed diverse business and vendor contracts across multiple third-party services to assess inherent and residual risks. Utilized risk assessment methodologies to evaluate contract terms and associated risks comprehensively. Presented findings to stakeholders to facilitate informed decision-making and risk mitigation strategies. This systematic approach enhanced the organization's understanding of vendor risks, optimized vendor selection processes, and minimized potential disruptions and liabilities associated with third-party engagements.
- Gathered evidence and compared the company's current security posture with the requirements of PCI DSS version 3.2.1 and created a Gap Analysis (GA). Recommended updates and changes to company systems and processes to align with the applicable Self Assessment Questionnaire (SAQ) and above and beyond with the Report on Compliance (ROC) based on the results of the GA. This ensured the company maintained and achieved compliance and avoided costly fines.
- Ensured vulnerabilities on the company website were patched promptly. This was accomplished by updating plugins to the latest version, removing unused plugins, etc thereby hardening the website security and allowing business as usual to proceed.

Cybersecurity Analyst | Success Marketing Services

June 2012 - March 2016

- Implemented controls aligned with internal standards and frameworks (NIST 800-53), collaborating with stakeholders to ensure compliance. Conducted thorough assessments of existing controls and identified gaps to be addressed. Developed and executed action plans to implement necessary controls, enhancing security posture and mitigating risks. This effort resulted in improved adherence to internal standards, strengthened resilience against potential threats, and bolstered overall organizational security.
- Collaborated with cross-functional teams to develop and implement security policies and procedures aligned with industry standards and regulatory requirements. Provided training and guidance to end-users and IT administrators to promote security awareness and adherence to security protocols. Strengthened the organization's defense against

- cyber threats and ensured compliance with regulatory mandates, safeguarding sensitive information and maintaining business continuity.
- Coordinated Qualys vulnerability scanning, ensuring timely identification and mitigation of vulnerabilities. Implemented patch deployment strategies to bolster system security and resilience, safeguarding critical assets and maintaining operational continuity.
- Collaborated with cross-functional teams to design and implement Azure Identity Protection policies, and Conditional Access policies. This effort strengthened Identity and Access Management (IAM) controls, mitigating the risk of unauthorized access or credential compromise.
- Implemented fraud detection software and prevention measures for online transactions by monitoring for suspicious activities and irregular patterns. This strengthened the company by potentially reducing financial losses, ensuring compliance with payment card industry standards, and minimizing operational disruptions.

Policy and Compliance Manager | Center for Psychotherapy

April 2008 - July 2012

- Enhanced security with Azure Private Link, Network Security Groups, and Microsoft Defender for Cloud. Ensured NIST 800-53, PCI DSS, and HIPAA/HITRUST compliance, leading to a 90% reduction in security incidents.
- Oversaw the development and implementation of improved office policies and procedures by focusing on standardization, improving employee performance, ensuring legal compliance, and reinforcing organizational values. This benefited the company by fostering operational efficiency, regulatory compliance, and employee engagement, leading to the organization's overall success.
- Checked and validated that all providers have up-to-date licenses and certifications by keeping track of expiration dates and setting relevant reminders. This helped the company by promoting compliance, quality assurance, brand reputation, and legal protection which indirectly contributed to the company's financial stability, and long-term success.
- Spearheaded the move away from handwritten patient notes by providers and the move towards implementing electronic health record (EHR) systems. This benefited the organization massively by improving efficiency, enhancing data security, and ensuring regulatory compliance (e.g. HIPAA) thereby increasing the company's ability to deliver high-quality healthcare services and achieve better patient outcomes.

Education

St. Francis College, Brooklyn NY
B.Sc. Business Studies with a Concentration in Aviation

August 2000 - June 2004

Certifications

Certified Information Security Manager (CISM)
Certified Information Systems Auditor (CISA)
CompTIA Security+ (Code: 42P1C49ZCEV4QZW4)
CompTIA CASP+ (Code: V308WT5ZCMVE143W)
Qualys PCI Compliance

Skills

NIST 800-37, NIST 800-53, NIST 800-61, NIST 800-30, NIST 800-39, NIST 800-171, NIST 800-190, NIST CSF 2.0, NIST Privacy Framework, ISO 27001, ISO 31000, PCI DSS 3.2.1, PCI DSS 4.0, GDPR, FTC, CCPA, HIPAA, CMMC, SOX, SOC 1, SOC 2, SOC 3, HITRUST CSF, CIS Controls, COBIT, FFIEC Cybersecurity Assessment Tool, FedRAMP, Basel III. Security Governance, Risk Management, Compliance Management, Enterprise Risk Management (ERM), Third-Party Risk Management (TPRM), Vendor Risk Assessments, Risk Assessment and Mitigation, Business Impact Analysis (BIA), Compliance Gap Analysis, Threat & Vulnerability Risk Assessment (TVRA), Continuous Control Monitoring (CCM), Regulatory Compliance, Security Posture Assessment, Security Audits, Audit Readiness, Internal & External Audit Support, Evidence Collection & Compliance Documentation, Control Testing & Validation, Policy Enforcement & Exception Management, Compliance Monitoring & Reporting, Cyber Risk Quantification, Self-Assessment Questionnaires (SAQs), Report on Compliance (ROC), Attestation of Compliance (AOC). Identity and Access Management (IAM), Authentication Methods (MFA, Biometrics), Access Control, Role-Based Access Control (RBAC), Privileged Access Management (PAM), Identity Federation, Least Privilege Enforcement, Compliance-Driven IAM Reviews, Separation of Duties (SoD). Data Governance, Data Classification, Data Retention Policies, Privacy Impact Assessments (PIA), Data Protection Impact Assessments (DPIA), Encryption & Compliance Controls, Secure Software Development Compliance (DevSecOps GRC), Cloud Security Governance. Security Policies and Procedures, Security Policy Development, Policy & Procedure Gap Analysis, Regulatory Interpretation & Compliance Guidance, Security Awareness Training, Social Engineering Awareness, Phishing Prevention, Social Engineering Training, User Awareness Programs, Stakeholder Engagement & Training, Executive-Level Reporting, Compliance Metrics & Key Risk Indicators (KRIs). Archer GRC, RSA Archer, ServiceNow, Qualys, Microsoft Power BI, OneTrust, LogicGate, AuditBoard, ZenGRC, Galvanize. Soft Skills: Communication Skills, Problem-Solving, Collaboration and Teamwork.

Kevin Alexander, CISA, CISM, PMP

- Jacksonville, FL, US

Contact Information

- k0i-cf9-c2h@mail.dice.com
- 9049179238

Summary

Governance, Risk and Compliance Specialist, adept at assisting organizations in achieving and sustaining PCI DSS compliance. Strives to minimize scope effectively, leading to cost savings for the company and enhancing overall profitability. Results-oriented professional with a demonstrated history of effectively implementing and overseeing comprehensive security measures to protect sensitive PCI data and ensure adherence to industry regulations. Committed to delivering tangible outcomes and preserving organizational assets through the application of cutting-edge security practices. Proficient in conducting meticulous risk assessments, formulating and executing strategies to enhance both physical and digital security, and establishing resilient control frameworks. Bringing experience in overseeing incident response protocols and collaborating with diverse stakeholders to uphold PCI compliance. Skilled in constructing and leading high-achieving security teams, fostering a culture of continual improvement.

Work History

Total Work Experience: 17 years

- Senior Enterprise Cybersecurity Governance Specialist Lexvorvin
Oct 01, 2023
- Cybersecurity Specialist EMK Properties
Jun 01, 2016
- Cybersecurity Analyst Success Marketing Services
Jun 01, 2012

- **Policy And Compliance Manager** Center For Psychotherapy
Apr 01, 2008

Education

- **Bachelors** | St Francis College

Skills

- **compliance** - 17 years
- **policies** - 17 years
- **security** - 17 years
- **business continuity** - 16 years
- **compliance management** - 16 years
- **cyber security** - 16 years
- **cybersecurity** - 16 years
- **data security** - 16 years
- **hardening** - 16 years
- **information security** - 16 years
- **information security governance** - 16 years
- **leadership** - 16 years
- **national institute of standards** - 16 years
- **risk management** - 16 years
- **security awareness** - 16 years
- **social engineering** - 16 years
- **authentication** - 13 years
- **controls** - 13 years
- **framework** - 13 years
- **payment card industry** - 13 years
- **pci dss** - 13 years
- **governance** - 10 years
- **project management professional** - 10 years
- **audit** - 9 years
- **nist** - 9 years
- **risk assessment** - 9 years
- **rsa archer** - 9 years
- **cryptography** - 8 years
- **multi-factor authentication** - 8 years
- **qa** - 8 years
- **hipaa** - 5 years

- asset **management**
- asset **security**
- business **development**
- business to business
- confidentiality
- copywriting
- **customer** satisfaction
- **cyber** defense
- **cyber risk management**
- cybersecurity tools
- **data** centers
- **data** privacy
- digital authentication
- digital marketing
- entrepreneurship
- incident response
- marketing
- **nist** 800 53
- payment card industry **data security**
- positioning
- post sales
- presentation **skills**
- **problem** solving
- **reporting** metrics
- request for proposal
- sales
- sales presentations
- sales processes
- social media
- standard operating procedure
- tam
- **threat** and **vulnerability management**
- virtualization
- **vulnerability** assessment
- **vulnerability management**
- **vulnerability** scanning

Work Preferences

- Desired Work Settings: Remote
- Likely to Switch: True
- Willing to Relocate: False
- Travel Preference: 0%

- Work Authorization:
 - US
- Work Documents:
 - US Citizen
- Security Clearance: False
- Desired Hourly Rate: 65+ (USD)
- Third Party: False
- Employment Type:
 - Full-time
 - Part-time
 - Contract - Corp-to-Corp
 - Contract - Independent
 - Contract - W2
 - Contract to Hire - Corp-to-Corp
 - Contract to Hire - Independent
 - Contract to Hire - W2

Profile Sources

- linkedin: <https://www.linkedin.com/in/kevin-t-alexander>
- Dice:
<https://www.dice.com/employer/talent/profile/54b54f58b28d08d55ae2abe087dd0e49>